智港通项目三工具静态代码扫描与标准化交付

标准操作规程（Standard Operating Procedure · SOP）

适用工程：SECP 调度服务、TOS-Hub 接入层服务 | 目标规范：three-tool-scan-delivery-1.0

文档编号：ZGT-SOP-SAST-001	当前版本：v1.2 (正式发布版)
编制单位：代码安全与架构治理组	生效日期：2026-10-25
适用环境：WSL Ubuntu 22.04 / Ubuntu 24.04	密级属性：项目合作方内部受控

1 目的与适用范围

1.1 1.1 规程目的

本规程旨在指导智港通（Zhigangtong）工程团队在本地开发编译环境（如 WSL Ubuntu 22.04）中，基于最新版 `three-tool-sast-runner` 自动化调度三套开源静态分析引擎（Cppcheck 2.22+、Clang-Tidy 14+、Clang Static Analyzer 14+），为 SECP 与 TOS-Hub 两个交付组件生成自包含、不可篡改、符合 IEC 62443 现场审计标准的高质量交付数据包。

1.2 1.2 责任与执行边界

本规程的设计遵循“安全底线由系统架构保证，不增加开发负担”的原则：

1. 源码资产安全：扫描完全在贵方本地离线执行，任何源码文件均不向外部传输，产出的交付 ZIP 仅包含分析器原生结构化证据与执行回执；
2. 审计责任清晰：本规范界定自研业务代码的静态扫描（SAST），引入的未修改开源第三方库（如 `tinyxml2`、`json.hpp`、`httplib.h`）在扫描中如实记录原生状态，后续由我方统一纳入组件清单与误报合规说明，不要求业务开发人员承担第三方开源库的语法解释责任。

2 推荐预设配置文件（Preset Profiles）

为免除操作人员手动编辑 JSON 格式及路径通配符的负担，最新版工具仓库根目录下已内置预设配置文件目录 `profiles/`，拉取代码后可直接引用：

配置文件	对应组件	声明源码范围 (`included_paths`)	排除构建目录 (`excluded_paths`)
`profiles/secp.json`	`secp`	`src/**` (含其下全部 69 个 TU)	`build/**`, `build_*/**`
`profiles/tos_hub.json`	`tos_hub`	`src/**`, `pubcode/**` (含全部 44 个 TU)	`build/**`, `build_*/**`

注：Profile 内的 `target_id` 与 `configuration` 为下游元数据追踪标签（默认标记为 `cmake-existing-build`），无需现场改动。

3 阶段一：工具更新与环境自检（仅需执行一次）

3.1 3.1 拉取最新 Runner 仓库

在 WSL 终端中进入工具仓库目录，拉取包含最新修复的代码：

```
cd ~/work/three-tool-sast-runner
git pull origin main  # 确保包含最新提交（支持多目标自动去重与 build* 通配）
```

3.2 3.2 依赖就绪核查

Runner 依赖 Python 3.12 与 PyYAML 6.0.3。在受限网络环境下，可指定国内镜像安装：

```
# 激活环境并确认 PyYAML 锁定版本
uv sync --frozen || uv pip install -i https://pypi.tuna.tsinghua.edu.cn/simple PyYAML==6.0.3
```

3.3 3.3 运行环境预检脚本

```
export PATH="$PWD/.venv/bin:$PATH"
bash install/preflight.sh
```

通过标准：终端输出显示 `[OK]` 涵盖 `clang-tidy`、`cppcheck`、`clang`、`clang++` 以及 `pyyaml: 6.0.3` 即代表环境准备就绪。

4 阶段二：产品标准化扫描与一键生成

4.1 4.1 SECP 组件扫描与交付规程

1. 工作区纯净度核查：

   ```
   cd /home/amor/work/100901_secp_scan
   git status --porcelain
   ```

   前置要求：输出必须为空。若有未跟踪的构建临时文件，请在 `.gitignore` 中忽略；若有已确认的修改（如 `LockClass.h`），请事先 `git commit` 入库。
2. 确认编译数据库： 确认 CMake 已导出 `build/compile_commands.json`（或 `compile_commands.json`）。工具已自动兼容多目标同一源文件的不同宏定义，无需手动去重。
3. 执行一键生成命令（Profile 直接引用 Runner 仓库内置文件）：

   ```
   cd ~/work/three-tool-sast-runner
   RUN_ID="secp-$(date +%Y%m%d_%H%M%S)"
   mkdir -p ~/work/results ~/work/deliveries

   uv run --frozen --offline python scan/deliver.py \
     --profile profiles/secp.json \
     --scan-path /home/amor/work/100901_secp_scan/src \
     --result-path ~/work/results/$RUN_ID \
     --output ~/work/deliveries/secp-delivery.zip
   ```

4.2 4.2 TOS-Hub 组件扫描与交付规程

1. 工作区纯净度核查：

   ```
   cd /home/amor/work/080400-tos-hub-v2
   git status --porcelain
   ```

   前置要求：输出必须为空。
2. 确认编译数据库： 工具现已原生自动支持识别 `build_n4/compile_commands.json`，无需再手动重命名目录。
3. 执行一键生成命令（注意：tos_hub 包含 `src` 与 `pubcode` 两个目录）：

   ```
   cd ~/work/three-tool-sast-runner
   RUN_ID="tos_hub-$(date +%Y%m%d_%H%M%S)"
   mkdir -p ~/work/results ~/work/deliveries

   uv run --frozen --offline python scan/deliver.py \
     --profile profiles/tos_hub.json \
     --scan-path /home/amor/work/080400-tos-hub-v2/src \
   ```

```
--scan-path /home/amor/work/080400-tos-hub-v2/pubcode \
--result-path ~/work/results/$RUN_ID \
--output ~/work/deliveries/tos_hub-delivery.zip
```

5 交付前 30 秒自检核对表

在向我方交付 ZIP 文件前，操作员请对照下表进行快速验收：

核验项目	达标标志	说明与处置
1. 命令退出码	`Exit: 0`	若退出码非 0（如 2 或 3），说明门禁未过，严禁交付半成品。
2. JSON 状态字段	`"status": "delivered"` `"scan_status": "completed"`	证明三工具全量 TU 扫描与逐文件收据验证已全部闭环。

3. 产物结构形态	ZIP 根目录下直接平铺：
	`manifest.json`
	`delivery-receipt.json`
		产物已自动完成自检，防篡改校验码匹配。严禁外层多包裹目录。

4. 源码可追溯性	`manifest.json` 中 `commit` 为 40 位真实 Git Commit 哈希	杜绝了版本未验证风险，与现场部署版本完全对应。

6 交付文件与交接窗口

自检全部通过后，仅需将以下两个标准 ZIP 文件移交给我方：

- `~/work/deliveries/secp-delivery.zip`
- `~/work/deliveries/tos_hub-delivery.zip`

我方流水线接收后，将全自动完成严格映射对账、生成中英文报审版 PDF 主报告与离线阅读包。如在执行过程中遇到任何非预期报错，请将控制台输出的完整 JSON 错误回传，我方技术团队将第一时间提供点对点技术支持。